Vulnerability Assessment Report

Website Tested: http://demo.testfire.com

1. Introduction

This report presents a basic security assessment of a live website using safe and passive testing methods. The goal was to identify common security issues and provide simple recommendations to improve overall website security.

2. Tools Used

- **Browser Developer Tools** (for headers and cookies analysis)
- **OWASP ZAP** (for passive vulnerability scanning)
- **Nmap** (for port and exposure analysis)

3. Methodology

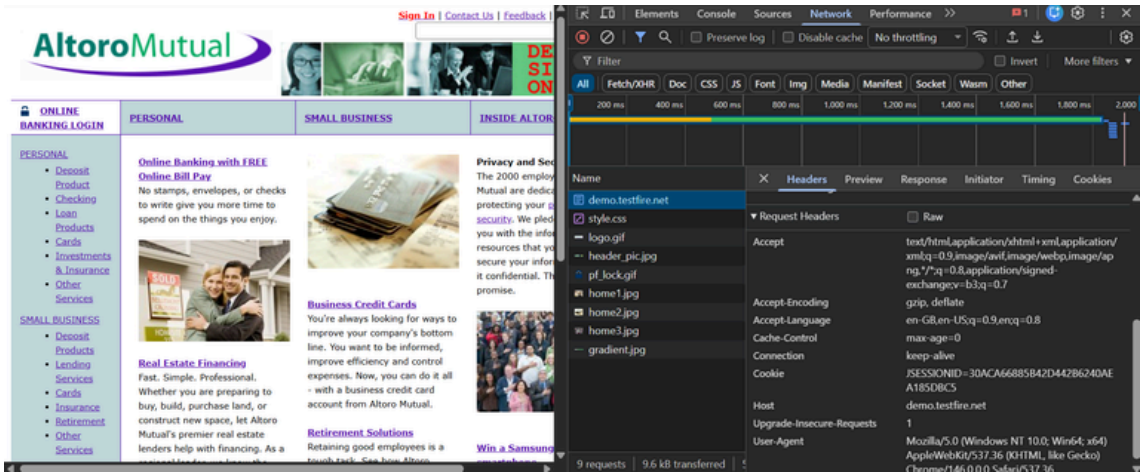
- Inspected website headers and cookies using Browser Developer Tools
- Identified security misconfigurations such as missing headers and insecure cookies
- Performed passive vulnerability scanning using OWASP ZAP
- Analyzed detected issues and classified them based on risk level (Low / Medium)
- Conducted port scanning using Nmap to identify open ports and exposed services.

4. Identified Vulnerabilities

Security Header Issues (DevTools)

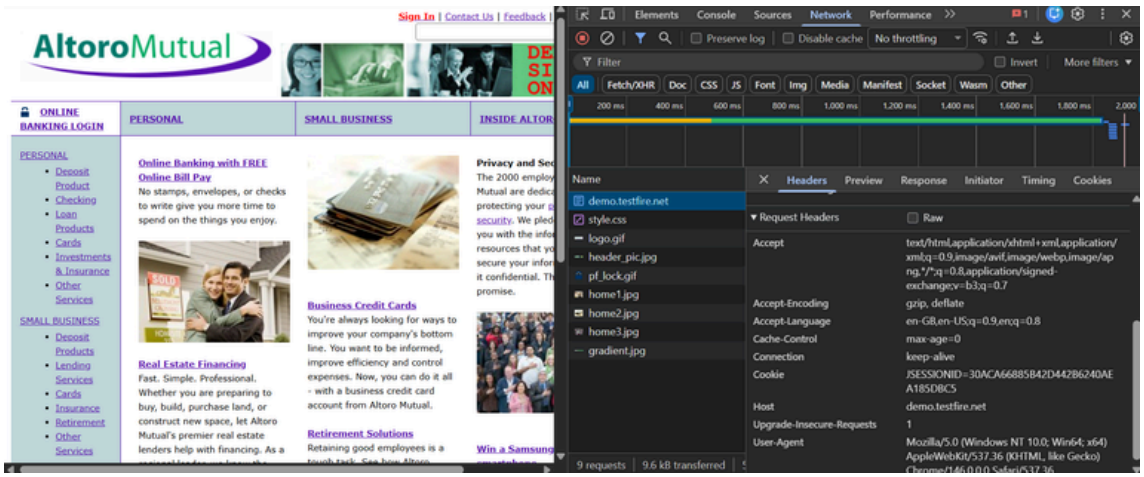
4.1 Missing Content Security Policy (CSP)

- **Risk Level:** Medium
- **Explanation:** The website does not define rules for what content can be loaded. This can allow harmful scripts to run.
- **Fix:** Add a Content Security Policy to restrict unsafe content.



4.2 Missing X-Frame-Options Header

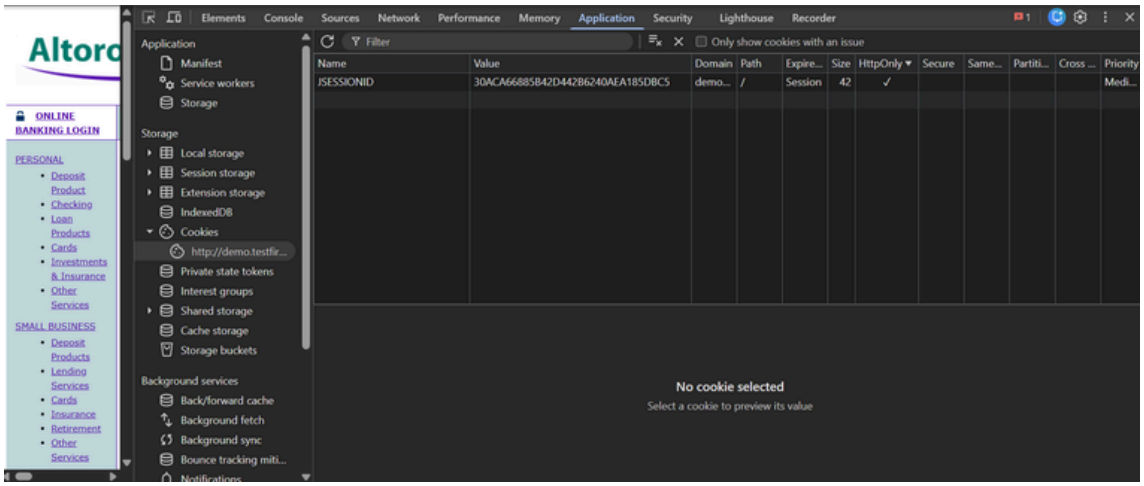
- **Risk Level:** Medium
- **Explanation:** The website can be embedded inside other websites, which may trick users into clicking hidden elements.
- **Fix:** Set X-Frame-Options to “DENY” or “SAMEORIGIN”.



Cookie Security Issues

4.3 Cookie Missing Secure Flag (DevTools)

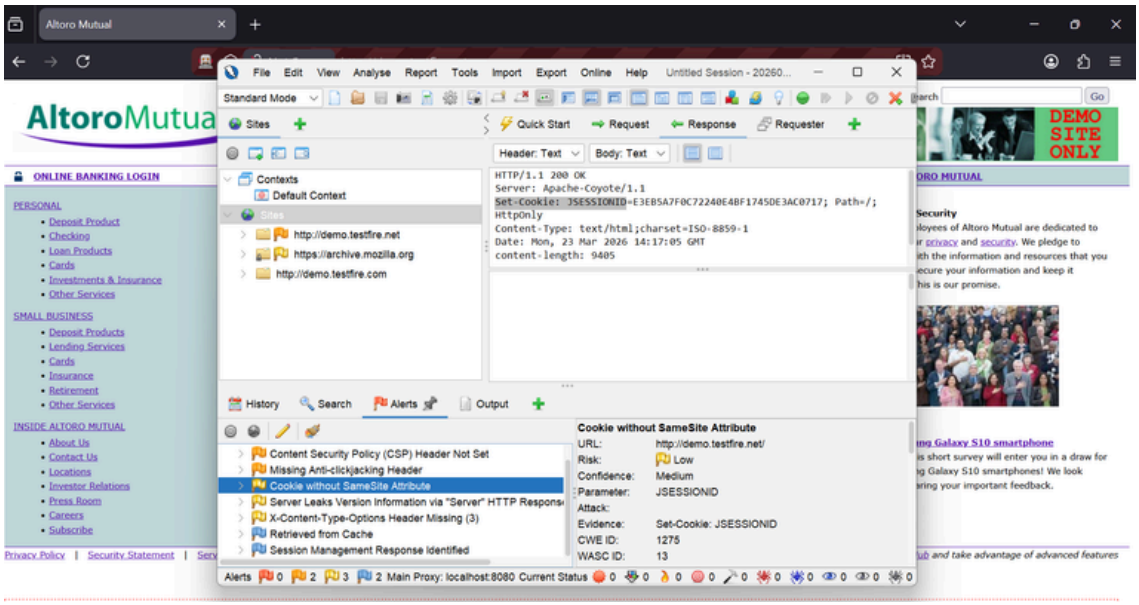
- **Risk Level:** Medium
- **Explanation:** Cookies can be sent over insecure connections, which may expose user data.
- **Fix:** Enable the Secure flag so cookies are only sent over HTTPS.



4.4 Cookie Missing SameSite Attribute (OWAP ZAP)

- **Risk Level:** Low

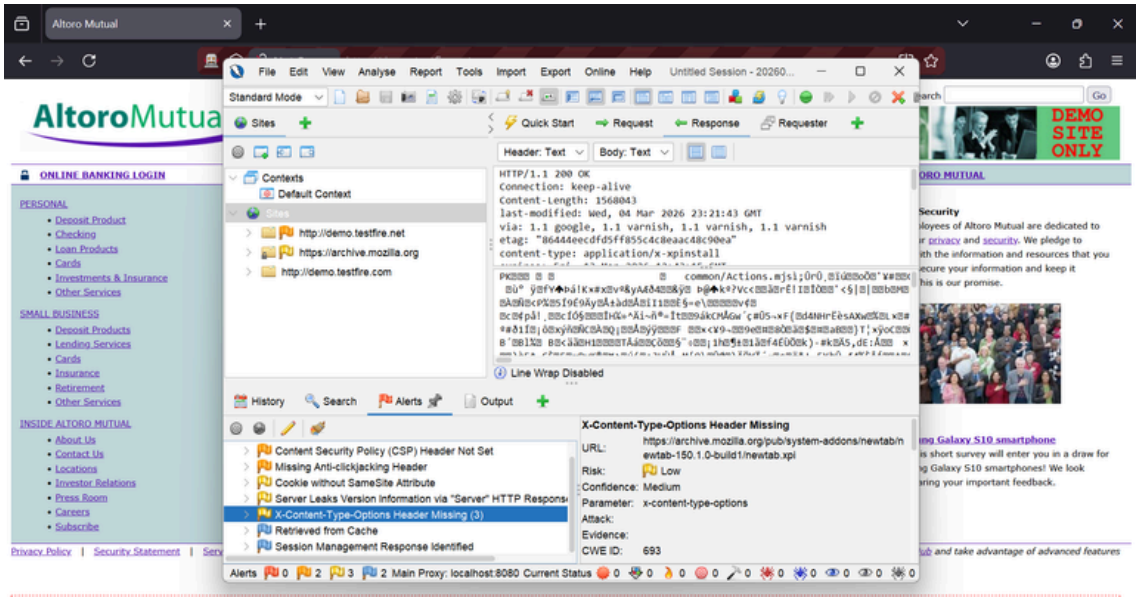
- **Explanation:** Cookies can be sent with external requests, increasing the risk of unauthorized actions.
- **Recommendation:** Set SameSite to “Strict” or “Lax”.



OWASP ZAP Analysis

4.5 Missing X-Content-Type-Options

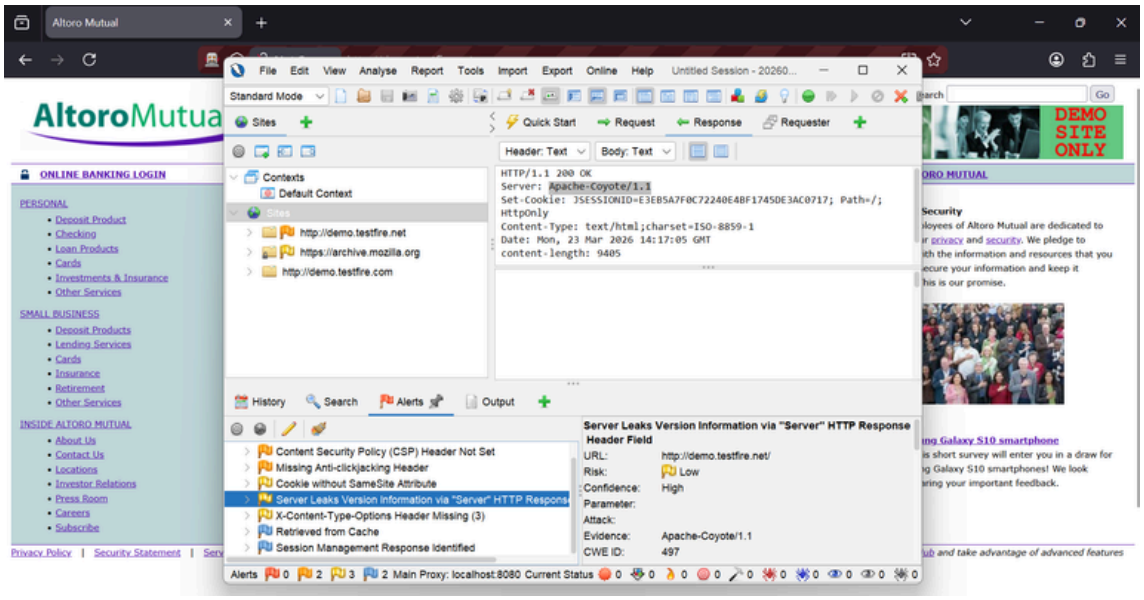
- **Risk Level:** Low
- **Explanation:** The browser may incorrectly interpret file types, which can lead to security risks.
- **Fix:** Set header to “nosniff”.



4.6 Server Version Disclosure

- **Risk Level:** Low

- **Explanation:** The server reveals its software version, which may help attackers find weaknesses.
- **Fix:** Hide or remove server version details.

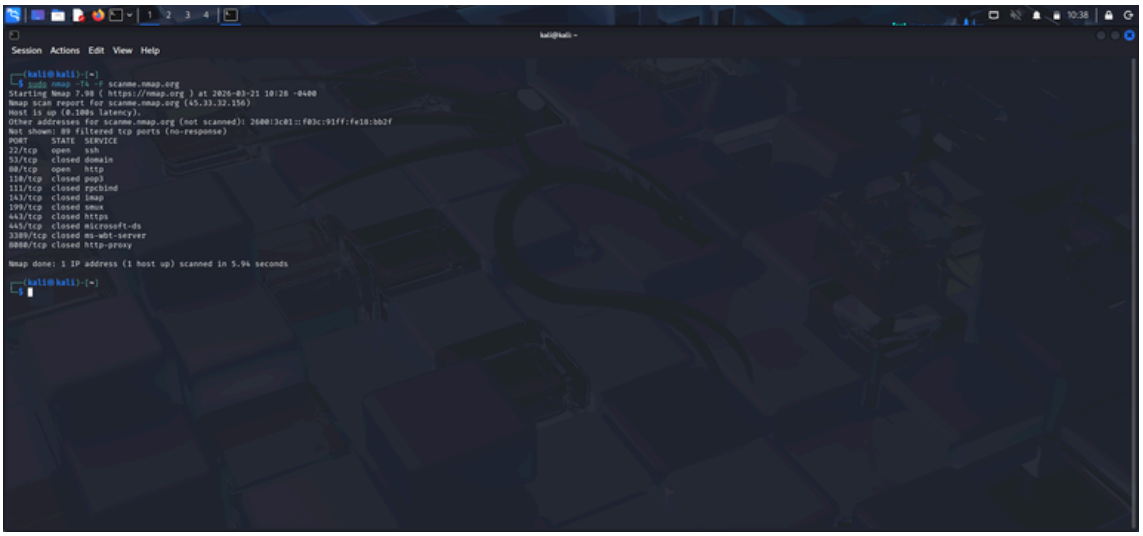


5. Nmap Port Scan Results

- **Target Used:** scanme.nmap.org

(Used due to scanning limitations on the main website)

Port 22 (SSH) – Open
Port 80 (HTTP) – Open



- **Risk:** Open ports may expose services if not properly secured.
- **Recommendation:** Restrict access to sensitive ports like SSH. Close unnecessary ports. Use secure protocols such as HTTPS.

6. Conclusion

This report presents a basic security assessment of a live website using safe and passive testing methods. The goal was to identify common security issues and provide simple recommendations to improve overall website security.